DomiAffaire: ISO/IEC 5055 review A

Knowledge-only code review by Claude Code · 2026-10-15 · Step 2 of the audit (github.com/inesCherif/domiaffaire-iso5055-audit)

> **Method.** The analyst read the code only (about 6,800 lines of Java in `api` and `chatapp`, plus the key Angular files). It used no scanner, no internet and **not the ISO 5055 text**; CWE numbers are from memory. Step 3 checks them against the standard.

Results per ISO 5055 characteristic

Characteristic	Findings	Critical	High	Medium	Low / Info
Security	21	5	6	6	4
Reliability	18	0	3	11	4
Performance Efficiency	8	0	2	6	0
Maintainability	14	0	2	7	5
Total	**61**	**5**	**13**	**30**	**13**

The five most important problems

1. **Broken access control (S07–S13).** The API checks the role, never the owner. Any client can delete any account, edit any profile (even demote the admin), and read other clients' ID-card files and chats.
2. **Secrets in code (S04, S05).** The JWT signing key is in the public repo, so tokens can be forged. Accountant sign-up is protected only by the code `abcd`.
3. **Password hashes exposed (S01–S03).** A *public* endpoint lists all users with their bcrypt hash, and many responses embed full `User` objects.
4. **Chat service without authentication (S14).** Anyone can read any room or write as anyone.
5. **Performance design (P01, P02).** A scheduler reloads every deadline, with attached files, every second. Files are stored inside documents and returned in every list.

Top findings with evidence

ID	Sev.	Finding	Where	CWE (recalled)
S01	Critical	**Public endpoint returns every user with password hash** GET /api/auth/clients is under the permitAll rule for /api/auth/** and returns userRepository.findAll(): every User entity, including pwd (bcrypt hash), role, phone, birth date and the accountant code.	`api/controllers/AuthController.java:105-109`	CWE-200 / CWE-862
S04	Critical	**Hard-coded JWT signing key** The HMAC key is a literal in source code. The repository is public, so anyone can forge a valid token for any e-mail, including the admin.	`api/utils/JwtUtil.java:65`	CWE-798 (CWE-321)
S07	Critical	**Any client or accountant can delete any account** DELETE /api/users/delete/{email} deletes whatever e-mail is given; no check that it is the caller's own account (admins can be deleted too).	`api/controllers/UserController.java:109-117`	CWE-639 / CWE-862

S08	Critical	**Profile update by path id: overwrite other users and their role** updateUser(..., id) loads the user from the URL id and forces userRole=CLIENT/ACCOUNTANT. A client can change another user's name, phone and photo, and demote an ADMIN to CLIENT.	`api/controllers/ClientController.java:44-60`	CWE-639
S09	High	**Clients can read other clients' domiciliation files** GET /api/clients/domiciliation-requests/{id} has no ownership check and returns ID-card (CIN) files, contracts and business licences (with file bytes).	`api/controllers/ClientController.java:172-179`	CWE-639
S14	Critical	**Chat service has no authentication; sender id is trusted from the client** The STOMP endpoint accepts anyone. The userId header decides who 'sent' the message, and anyone can subscribe to /topic/{roomId} to read a conversation.	`chatapp/controllers/WebSocketController.java:15-18`	CWE-306 / CWE-290
R04	High	**Contract acceptance can crash and poison the scheduler** If a client accepts before the admin answered, getResponseDomiAdmin() is null (NPE). If paymentMode is null, limitedDate stays null and checkDeadlines() throws NPE every second.	`api/services/DomiAffaireServiceImpl.java:787-824`	CWE-476
R12	High	**Bad-word filter rejects normal business words** Substring matching on short words ("con", "cul", "pd", "tg") blocks words like contrat, consultation, compte, calcul: exactly the vocabulary of this business.	`chatapp/validators/NoBadWordsValidator.java:21`	CWE-697
P01	High	**Scheduler reloads all deadlines every second** @Scheduled(fixedRate = 1000) loads every domiciliation request with a deadline, each with about 10 eager @DBRef objects (files with their bytes, users with photos): 86,400 times a day.	`api/services/DeadlineServiceImpl.java:44-46`	CWE-1050
P02	High	**File contents stored inside documents and sent in every list** byte[] fileData / image are loaded through @DBRef whenever a request, blog, chat or user is read, and serialised as base64 in list responses (e.g. all domiciliation requests with up to 9 files each).	`api/entities/File.java:21`	CWE-1049 (approx.)
M01	High	**God class: DomiAffaireServiceImpl** Users, files, chats, consultations, domiciliation, packs, blogs, FAQs and reporting all live in one class.	`api/services/DomiAffaireServiceImpl.java (1,585 lines, about 70 methods, 15 repositories)`	CWE-1080 / CWE-1048
M02	High	**Heavy code duplication** The same code is copied many times: three sendDomiciliationRequest variants, the 'find authenticated user' block, the upload type check (x6), identical blog/chat endpoints in Client/Accountant/User controllers, two branches of updateUser.	`api/services/DomiAffaireServiceImpl.java:390-595 (3 near-identical methods), File.builder block x12, auth-user lookup x~35`	CWE-1041

All findings

ID	Characteristic	Sev.	Finding	CWE (recalled)	In ISO 5055? (guess)
S01	Security	Critical	Public endpoint returns every user with password hash	CWE-200 / CWE-862	Unsure
S02	Security	High	Public lookup of any user by e-mail (enumeration + data exposure)	CWE-200 / CWE-204	Unsure
S03	Security	High	Password hashes leak through DTOs that embed User entities	CWE-200	Unsure
S04	Security	Critical	Hard-coded JWT signing key	CWE-798 (CWE-321)	Yes
S05	Security	High	Hard-coded accountant registration code "abcd"	CWE-798	Yes

S06	Security	Medium	Admin credentials left in comments	CWE-615 / CWE-798	Unsure
S07	Security	Critical	Any client or accountant can delete any account	CWE-639 / CWE-862	Unsure
S08	Security	Critical	Profile update by path id: overwrite other users and their role	CWE-639	Unsure
S09	Security	High	Clients can read other clients' domiciliation files	CWE-639	Unsure
S10	Security	High	Clients can cancel other clients' requests	CWE-639	Unsure
S11	Security	Medium	Clients can accept/protest contracts of other clients	CWE-639	Unsure
S12	Security	High	Any client/accountant can read any chat	CWE-639	Unsure
S13	Security	Medium	Accountants can modify or delete anyone's blog posts	CWE-639 / CWE-862	Unsure
S14	Security	Critical	Chat service has no authentication; sender id is trusted from the client	CWE-306 / CWE-290	Unsure
S15	Security	Medium	CORS allows any origin and any header	CWE-942	Unsure
S16	Security	Medium	No protection against password guessing on login	CWE-307	Unsure
S17	Security	Medium	Upload checks trust the client Content-Type	CWE-434	Yes
S18	Security	Low	JSON built by string concatenation with untrusted text	CWE-116	Unsure
S19	Security	Low	Angular sanitizer bypassed on consultation details	CWE-79	Yes
S20	Security	Info	OAuth client secret was in the properties file (now a placeholder)	CWE-798	Yes
S21	Security	Low	Chat content and data written to the browser console	CWE-532	Unsure
R01	Reliability	High	Optional.get() without check: unknown ids crash with HTTP 500	CWE-754 (CWE-476)	Unsure
R02	Reliability	Medium	String fields compared without null check	CWE-476	Yes
R03	Reliability	Medium	Operator-precedence bug in every file-type check	CWE-783	Unsure
R04	Reliability	High	Contract acceptance can crash and poison the scheduler	CWE-476	Yes
R05	Reliability	Medium	Reminder/overdue flag logic is inconsistent	CWE-670	Unsure
R06	Reliability	Medium	Room double-booking: overlap check only matches identical slots	CWE-697	Unsure
R07	Reliability	Medium	Money computed with float	CWE-681 / CWE-1339	Unsure
R08	Reliability	Medium	Hard-coded absolute Windows paths of the author's PC	none certain	No
R09	Reliability	Medium	Exceptions swallowed with printStackTrace	CWE-390	Yes
R10	Reliability	Medium	Lombok @Builder drops field defaults	CWE-665	Unsure
R11	Reliability	Medium	Seed data parsed wrongly and re-written at every start	CWE-20	Unsure
R12	Reliability	High	Bad-word filter rejects normal business words	CWE-697	No
R13	Reliability	Medium	Uncaught JWT and login exceptions return 500	CWE-248 / CWE-755	Unsure
R14	Reliability	Low	Possible infinite recursion in toString/hashCode	CWE-674	Unsure
R15	Reliability	Medium	Front end never releases subscriptions or the WebSocket	CWE-772 / CWE-401	Yes

R16	Reliability	Low	Silent failures and broken features	CWE-754	Unsure
R17	Reliability	Low	Generic RuntimeException wrapping and malformed error bodies	CWE-397	Unsure
R18	Reliability	Low	Phone-number regex has a broken character class	CWE-185	Unsure
P01	Performance Efficiency	High	Scheduler reloads all deadlines every second	CWE-1050	Yes
P02	Performance Efficiency	High	File contents stored inside documents and sent in every list	CWE-1049 (approx.)	Unsure
P03	Performance Efficiency	Medium	N+1 queries on deadlines	CWE-1060 (approx.)	Unsure
P04	Performance Efficiency	Medium	Database calls inside loops	CWE-1050	Yes
P05	Performance Efficiency	Medium	Full collection scans and in-memory filtering	CWE-1049 (approx.)	Unsure
P06	Performance Efficiency	Medium	Pack embeds full User documents (unbounded growth)	none certain	Unsure
P07	Performance Efficiency	Medium	Chat history list grows forever and is rewritten on each message	CWE-1050 (approx.)	Unsure
P08	Performance Efficiency	Medium	No pagination on any list endpoint	CWE-1049 (approx.)	Unsure
M01	Maintainability	High	God class: DomiAffaireServiceImpl	CWE-1080 / CWE-1048	Yes
M02	Maintainability	High	Heavy code duplication	CWE-1041	Yes
M03	Maintainability	Medium	Dead and commented-out code	CWE-561 / CWE-563	Yes
M04	Maintainability	Low	Conditions that are always true	CWE-571	Unsure
M05	Maintainability	Medium	Layering bypassed: controllers use repositories and concrete classes	CWE-1057	Yes
M06	Maintainability	Medium	Magic numbers and hard-coded literals	CWE-1106	Yes
M07	Maintainability	Medium	Same domain model duplicated in two services	CWE-1041	Yes
M08	Maintainability	Medium	Outdated, conflicting or incompatible dependencies	CWE-1104	Yes
M09	Maintainability	Low	Debug output left in code	CWE-489	Unsure
M10	Maintainability	Medium	Long, deeply nested methods	CWE-1121	Yes
M11	Maintainability	Low	Too many parameters	CWE-1064	Yes
M12	Maintainability	Low	Unclear or misleading text in code	none	No
M13	Maintainability	Low	State changes through HTTP GET	none	No
M14	Maintainability	Medium	Almost no automated tests	none	No

Limits

- Nothing was executed for this review, and library CVEs were not checked.
- The mobile client and the Python recommendation service are out of scope.
- CWE labels and ISO 5055 membership are recalled, not verified. That is the purpose of step 3.
- Origins: 2 findings were seen during planning (S15, S20) and 1 during step 1 (M08); the permitAll rule behind S01 was also seen in step 1. All others come from the review.

Full report: `reports/02-review-knowledge.md` · data: `findings.csv`